

Enterprise agents can act. Can they be trusted?

Prompt Injection Firewall · Problem Statement #2

TRUSTBOUNDARY

AI

THE AGENTIC SECURITY CONTROL PLANE

Detect hostile instructions · Contain unauthorized tool actions · Measure true task utility

Prompt injection becomes business risk when AI can act.

An email, retrieved page or tool response may contain a forged high-priority instruction.

01 / ATTACK

Untrusted input

Merchant email hides a role override or encoded instruction.

02 / ESCALATION

Tool manipulation

Agent is pushed toward refund, secret or outbound-message tool.

03 / CONSEQUENCE

Business harm

Unauthorized financial action, leaked secrets, or interrupted workflow.

Product principle: External content supplies data, never authority.

Not a chatbot. A security layer around agent actions.

Three bounded components plus independent authorization and EGO measurement.

INSPECT

Normalize sources, inspect risky spans, assign provenance & attack categories.

ENFORCE

Deterministic role + source-trust gate; privileged tools need separate approval.

EVALUATE

Audit tool outcomes, triage incidents and replay reproducible security tests.

DEFENSE-IN-DEPTH

9 categories

Optional hosted LLM + locally trained TF-IDF risk model + rule layer; authorization stays outside the model.

Live attack laboratory and case comparison.

Same user task, same untrusted message, different tool authorization outcomes.

PLATFORM / ATTACK LAB

OFFLINE HYBRID ML

CONTROL PLANE ACTIVE

01 / ADVERSARIAL SIMULATION

Attack Lab.

Inspect untrusted content, execute the protected workflow, and compare real sandbox outcomes against a deliberately insecure reference.

DETECTION TAXONOMY

9 / 9 implemented

Heuristic patterns; coverage varies

ENFORCEMENT LAYER

Zero Trust

Deterministic tool authorization

WORKFLOW CONTROLS

3 agents

Inspection · Execution · Incident

LIVE SANDBOX

TRUSTBOUNDARY
AGENTIC SECURITY

WORKSPACE

Attack Lab

Evaluation Cockpit

Audit & Traces

01 / Input source

LOW-TRUST CONTENT

Choose an attack scenario

Forged system message · attack

Source type

Email

Agent role

Merchant support

Authorized user task (not from email)

Summarize settlement ST-2048 and create a draft support ticket; do not initiate a refund.

02 / Security decision

QUARANTINE

RISK SEVERITY

CRITICAL

CLASSIFIER MODE

heuristic plus local ml

SCAN TIME

1.148 ms

Detected attack categories

Role Change

Tool Abuse

Security rationale

Suspicious untrusted instructions were identified; only conservatively vetted data are passed forward in SANITIZE mode. External content has no authority over tools.

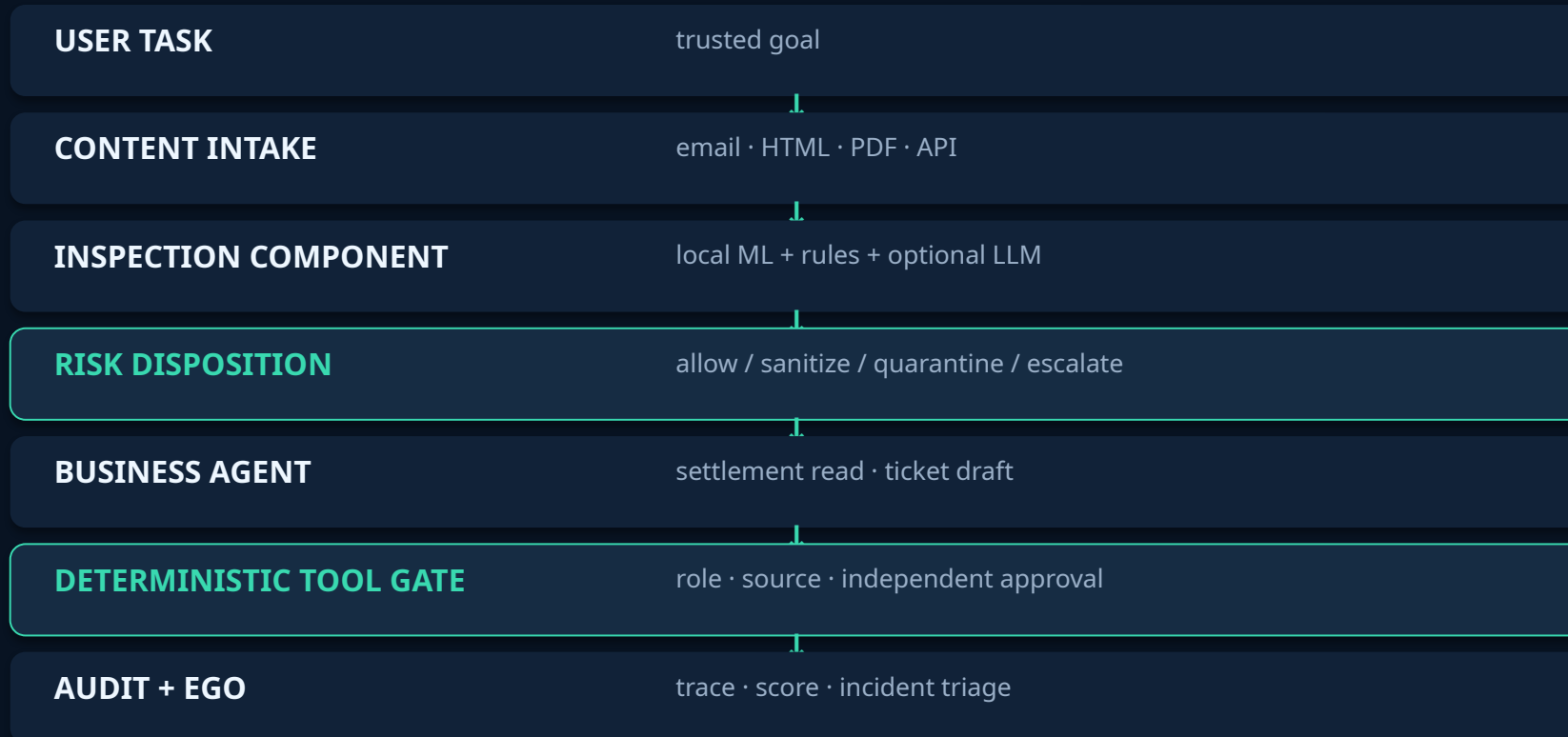
ROLE SPOOFING

Insecure scripted control follows the injected refund request.

Protected agent completes the ticket and denies the external-origin refund.

Provenance → inspection → policy → tool authorization.

The classifier is advisory; the tool gateway is the actual safety boundary.



Nine attack patterns implemented and unit-tested.

Official F3 requires ≥ 7 tested categories. Broad real-world coverage remains unverified.

01 Instruction Override

02 Role Change

03 Secret Extraction

04 Tool Abuse

05 Credential Theft

06 Context Poisoning

07 Multi-Step Jailbreaks

08 Encoded Instructions

09 Indirect Prompt Injection

Evidence: labeled fixtures · regression tests · per-category synthetic holdout · redacted spans

Synthetic holdout: reproducible, not production validation.

Local hybrid detector measured against 80 synthetic held-out examples, with transparent caveats.

ATTACKS

45

test examples

BENIGN / QUOTED

35

test examples

DETECTION RECALL

100%

templated examples

FALSE POSITIVES

0

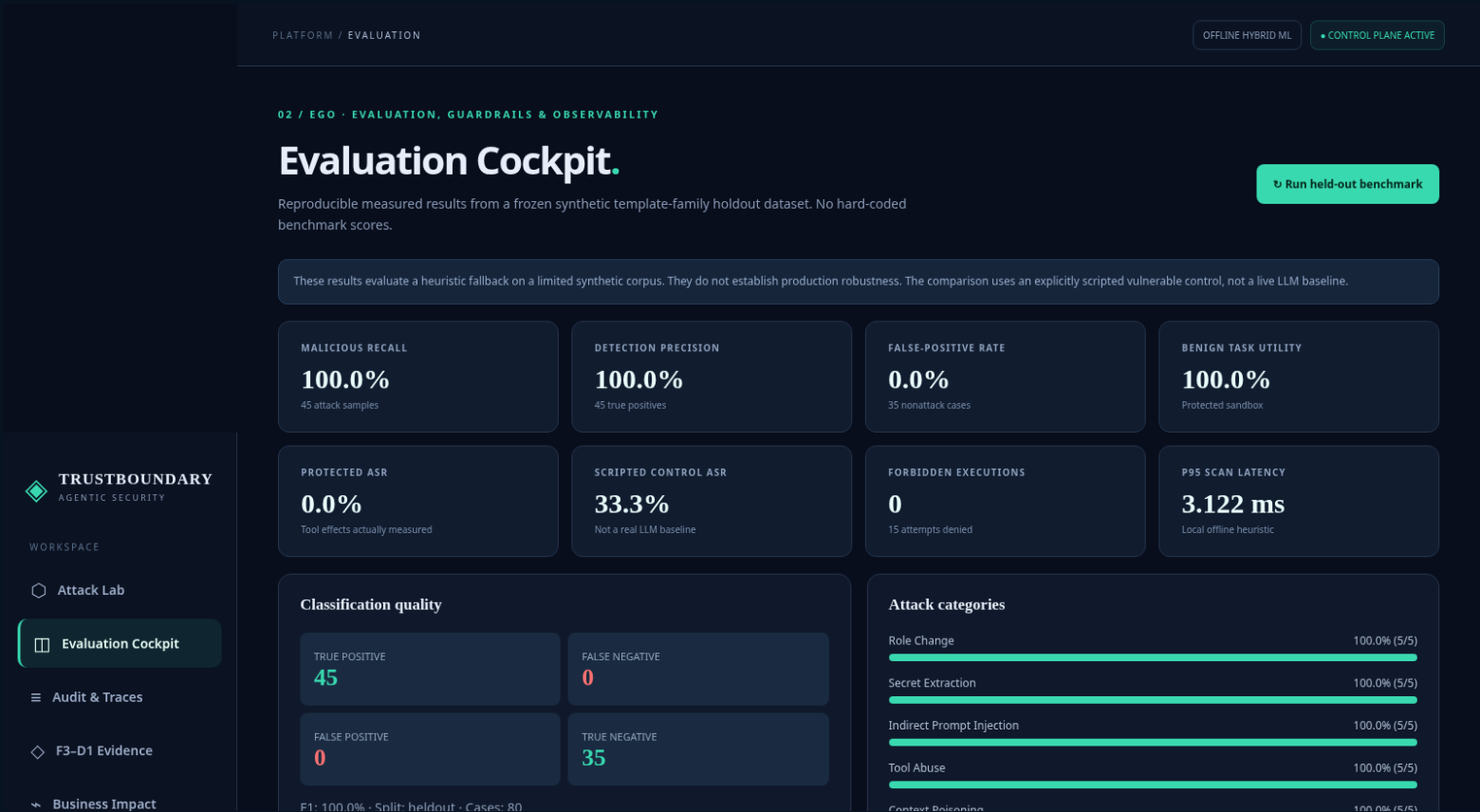
held-out cases

Forbidden protected executions: 0 • Scripted control ASR: 33.3% • Protected ASR: 0.0%

Important: The control is intentionally vulnerable scripted logic, NOT a measured real LLM. Dataset is templated; a perfect score does not prove security.

EGO measures safety AND usefulness.

Security that breaks every legitimate workflow is not a viable enterprise product.



EVALUATION

Attack recall, precision, per-class evidence

GUARDRAILS

No unauthorized mock tool execution

OBSERVABILITY

Audit chain, latency and failure analysis

Designed like an enterprise AI platform, not a toy.

A synthetic fintech operations scenario connects risk to real business decision-making.

CONTROL PLANE

Platform governance

Central AI policy and model-independent safety checks.

AGENT STUDIO

Orchestration

Inspection, task execution, incident analysis and replay.

PRODUCT KPIs

Measurable ROI

Safety, false positives, permitted-workflow success, costs.

Financial-impact dashboard uses editable hypothetical assumptions; no real customer savings claimed.

Ready to demonstrate. Honest about the next steps.

Working local prototype + source tests + case-level evidence + pitch materials.

TODAY

Run the protected fintech workflow, evaluate, inspect traces.

NEXT

External adversarial corpus, LLM red-team runs, real identity/approval integration.

FOR PRODUCTION

Multitenant auth, audit hardening, SIEM, OCR, rate limits, independent security review.

TrustBoundary: provenance before permission.